

	Detail
Course	GRC102 – Information Security Governance
Module	Module 2 – Developing Security Policies and Procedures
Name	Adebukola Olanipekun
Student Registration No.	C11/26/CGRCE/17603
Date Submitted	16/09/2026
Due Date	18 September 2026

Document Control

Field	Detail
Document Title	ICDFA Security Policy Manual
Policy Owner	Chief Information Security Officer (CISO)
Approval Authority	ICDFA Governing Council / Senior Management Board
Version	1.0
Effective Date	1 October 2026
Next Review Date	1 October 2027

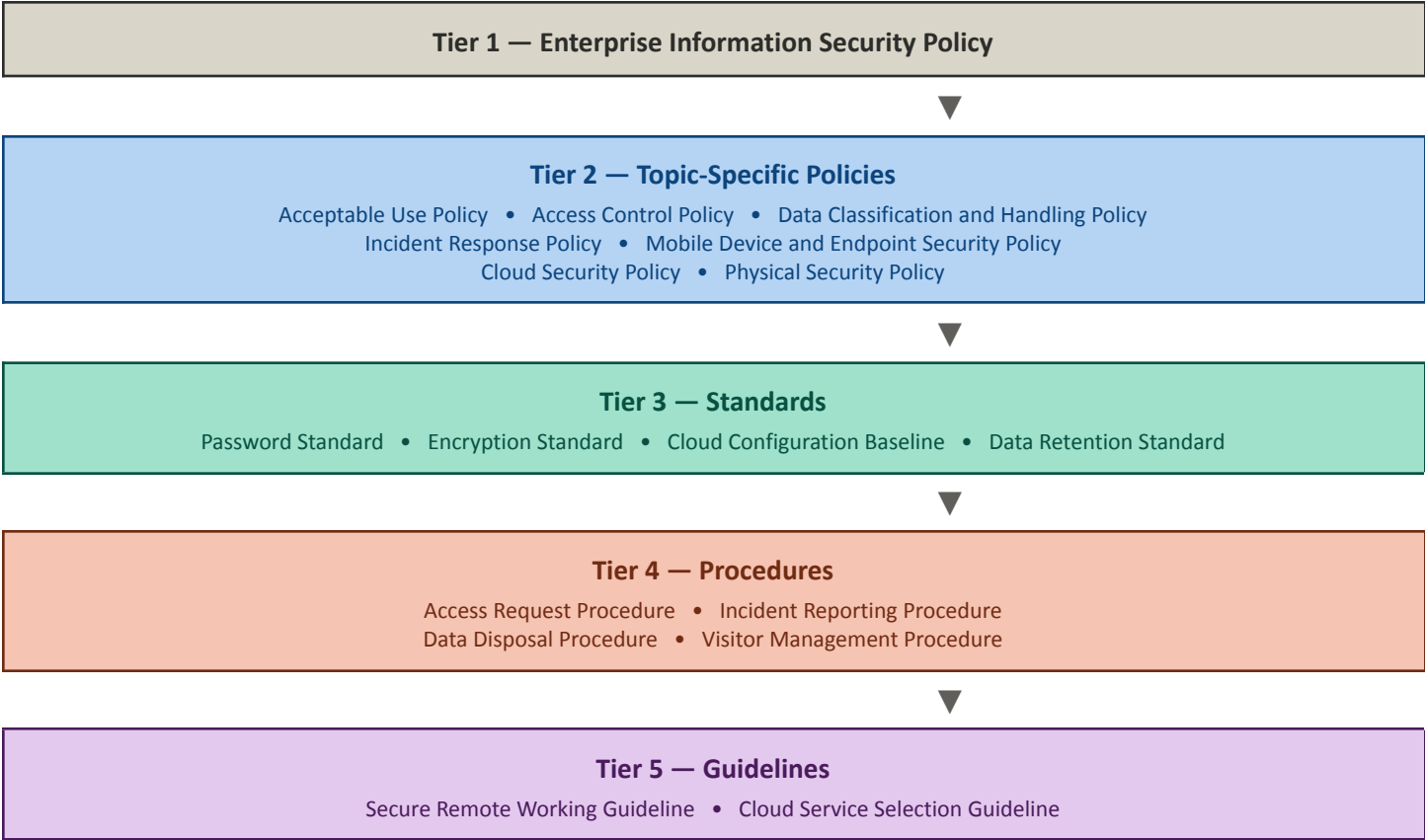
Task 1: Policy Governance Framework

1.1 Policy, Standard, Procedure, and Guideline

Document Type	Purpose	Authority	Example
Policy	States mandatory organizational intent, principles, and high-level requirements. Answers “what” must be done and “why.”	Approved by senior management; mandatory compliance.	“All access to ICDFA systems requires unique identification.”
Standard	Defines specific, measurable technical or operational requirements that support a policy. Answers “how much” or “to what specification.”	Approved by CISO or delegated authority; mandatory.	“Passwords must be minimum 12 characters with complexity.”
Procedure	Step-by-step instructions for performing a task or process. Answers “how” to implement policy/standard.	Approved by process owner; mandatory for the defined task.	“Step 1: Submit access request via ServiceDesk. Step 2: Manager approval...”
Guideline	Recommended best practice, advisory in nature. Provides guidance where strict compliance is not required.	Approved by policy owner; non-mandatory.	“Consider using a password manager for credential storage.”

Authority hierarchy: Policy > Standard > Procedure > Guideline. A procedure must not contradict a standard, and a standard must not contradict a policy.

1.2 Policy Hierarchy



1.3 Policy Lifecycle

Phase	Description	Responsible Party
Drafting	Policy owner drafts document using approved template.	Policy Owner
Consultation	Stakeholders review for practicality, conflicts, and completeness.	Policy Owner + Stakeholders
Approval	Final review and formal approval by designated authority.	Approval Authority (varies by tier)
Publication	Policy published to central repository accessible to all affected parties.	CISO / Compliance
Communication	Targeted awareness campaigns, training, and acknowledgement collection.	HR + CISO
Exception Management	Formal process for requesting, assessing, approving, and tracking exceptions.	CISO / Risk Committee

Phase	Description	Responsible Party
Review	Periodic review at least annually or upon significant change.	Policy Owner
Revision	Updates based on review findings, incidents, or regulatory changes.	Policy Owner
Retirement	Formal withdrawal when policy is obsolete or superseded.	Approval Authority

1.4 Stakeholder Responsibilities

Stakeholder	Responsibility
Governing Council / Senior Management	Approve enterprise policy; provide visible sponsorship; allocate resources.
CISO / Policy Owner	Draft, maintain, and review policies; oversee implementation; manage exceptions.
IT Operations	Implement technical controls supporting policy; provide operational input.
HR	Integrate policy requirements into onboarding/offboarding; deliver awareness training.
Legal / Compliance	Review for regulatory alignment; advise on legal obligations.
Managers	Ensure team compliance; approve access requests; report incidents.
All Users (Staff, Students, Instructors)	Read, acknowledge, and comply with policies; report violations and incidents.
Third Parties / Contractors	Comply with applicable policies per contractual agreements.

Governance Narrative: This framework establishes clear lines of authority and accountability, ensuring that ICDFA's security policies are not isolated documents but part of a coherent governance system. The hierarchy prevents contradictions, the lifecycle ensures currency, and defined stakeholder roles enable effective oversight and continuous improvement.

Task 2: IC DFA Security Policy Manual

Policy 1: Enterprise Information Security Policy

Owner	Approver	Version	Effective	Review
CISO	Governing Council	1.0	1 Oct 2026	1 Oct 2027

1. Purpose

To define IC DFA’s overall security direction, governance principles, authority, and organizational expectations for protecting information assets.

2. Scope

Applies to all IC DFA personnel, students, contractors, and third parties accessing IC DFA systems, networks, data, or facilities.

3. Definitions

- Information Asset: Any data, system, or facility with value to IC DFA.
- CISO: Chief Information Security Officer.

4. Roles and Responsibilities

- Governing Council: Ultimate accountability for information security.
- CISO: Develops, implements, and maintains the security program.
- All Users: Comply with policies and report incidents.

5. Policy Statements

- 5.1 IC DFA shall maintain an Information Security Management System (ISMS) aligned with ISO/IEC 27001:2022.
- 5.2 A risk-based approach shall be applied to all security decisions.
- 5.3 All information assets shall have an assigned owner.
- 5.4 Security requirements shall be integrated into all projects and system acquisitions.

6. Compliance / Framework Alignment

Aligned with ISO/IEC 27001:2022 (Clauses 4-10), NIST CSF 2.0 (GV, ID, PR, DE, RS, RC), and Nigeria Data Protection Act 2023.

7. Exceptions

Requests submitted via Exception Request Form; approved by CISO with documented compensating controls; maximum 12-month validity.

8. Enforcement

Non-compliance may result in disciplinary action up to termination or expulsion, and contract termination for third parties.

9. Monitoring and Metrics

Policy acknowledgement rate; number of policy exceptions; audit findings.

10. Review and Version Control

Annual review by CISO; revision upon significant change or incident.

11. Related Documents

- All topic-specific policies
- ISMS Scope Document

Policy 2: Acceptable Use Policy (AUP)

Owner	Approver	Version	Effective	Review
CISO	CISO	1.0	1 Oct 2026	1 Oct 2027

1. Purpose

To define appropriate and prohibited use of ICDFA devices, networks, accounts, applications, and digital resources.

2. Scope

All users accessing ICDFA IT resources, including personal devices connected to ICDFA networks.

3. Definitions

- ICDFA Resources: All computing devices, networks, applications, and data owned or managed by ICDFA.

4. Roles and Responsibilities

- Users: Use resources responsibly and in accordance with policy.
- IT Operations: Monitor usage and enforce controls.

5. Policy Statements

5.1 ICDFA resources shall be used primarily for academic, research, and administrative purposes.

5.2 Prohibited activities include: unauthorized access attempts, installing unlicensed software, using resources for illegal activities, and circumventing security controls.

5.3 Users shall not share credentials or leave authenticated sessions unattended.

5.4 Personal use is permitted only when it does not interfere with duties, consume excessive resources, or violate any law or policy.

6. Compliance / Framework Alignment

ISO/IEC 27001:2022 A.8.1 (User Endpoint Devices); NIST CSF PR.AC.

7. Exceptions

As per Enterprise Policy Section 7.

8. Enforcement

Violations may result in suspension of access, disciplinary action, or legal referral.

9. Monitoring and Metrics

Incident reports related to misuse; audit findings.

10. Review and Version Control

Annual review or upon significant change.

11. Related Documents

- Access Control Policy
- Mobile Device and Endpoint Security Policy

Policy 3: Access Control Policy

Owner	Approver	Version	Effective	Review
CISO	CISO	1.0	1 Oct 2026	1 Oct 2027

1. Purpose

To define identity, authentication, authorization, privileged access, account lifecycle, and access review requirements.

2. Scope

All human and non-human identities accessing ICDFA systems and data.

3. Definitions

- Privileged Access: Access that exceeds standard user permissions (e.g., administrator accounts).
- MFA: Multi-Factor Authentication.

4. Roles and Responsibilities

- System Owners: Approve access requests for their systems.
- IT Operations: Provision, modify, and revoke access.

5. Policy Statements

5.1 All access shall be based on the principle of least privilege.

- 5.2 Unique user IDs shall be assigned; shared accounts are prohibited unless technically unavoidable and documented.
- 5.3 MFA shall be required for all remote access and privileged accounts.
- 5.4 Access rights shall be reviewed at least quarterly for privileged accounts and annually for all other accounts.
- 5.5 Accounts shall be disabled within 24 hours of termination.

6. Compliance / Framework Alignment

ISO/IEC 27001:2022 A.5.15-A.5.18, A.8.2-A.8.5; NIST CSF PR.AC-1, PR.AC-4.

7. Exceptions

As per Enterprise Policy Section 7.

8. Enforcement

Unauthorized access attempts will result in immediate suspension and disciplinary action.

9. Monitoring and Metrics

Access review completion rate; number of orphaned accounts; MFA adoption rate.

10. Review and Version Control

Annual review.

11. Related Documents

- Password Standard
- Privileged Access Management Procedure

Policy 4: Data Classification and Handling Policy

Owner	Approver	Version	Effective	Review
CISO	CISO	1.0	1 Oct 2026	1 Oct 2027

1. Purpose

To define data classification levels and handling, storage, sharing, retention, and disposal expectations.

2. Scope

All data created, received, stored, or transmitted by ICDFA.

3. Definitions

- Classification Levels: Public, Internal, Confidential, Restricted.

4. Roles and Responsibilities

- Data Owners: Classify data and define handling requirements.
- All Users: Handle data according to its classification.

5. Policy Statements

5.1 All data shall be classified according to the ICDFA Classification Scheme.

5.2 Confidential and Restricted data shall be encrypted at rest and in transit.

5.3 Data retention periods shall be defined and enforced.

5.4 Data shall be securely disposed of when no longer required, using approved methods.

6. Compliance / Framework Alignment

ISO/IEC 27001:2022 A.5.12-A.5.14, A.8.10-A.8.12; NDPA 2023 (data protection principles).

7. Exceptions

As per Enterprise Policy Section 7.

8. Enforcement

Data breaches resulting from mishandling may result in disciplinary action.

9. Monitoring and Metrics

Percentage of data assets classified; encryption compliance rate.

10. Review and Version Control

Annual review.

11. Related Documents

- Data Retention Standard
- Data Disposal Procedure

Policy 5: Incident Response Policy

Owner	Approver	Version	Effective	Review
CISO	CISO	1.0	1 Oct 2026	1 Oct 2027

1. Purpose

To define incident reporting, escalation, roles, evidence preservation, communication, and post-incident review requirements.

2. Scope

All security incidents affecting ICDFA information assets.

3. Definitions

- Security Incident: Any actual or suspected breach of security.

4. Roles and Responsibilities

- All Users: Report incidents immediately.
- Incident Response Team (IRT): Investigate, contain, and remediate incidents.

5. Policy Statements

5.1 All incidents shall be reported within 1 hour of detection via the Incident Reporting Portal.

5.2 The IRT shall maintain an Incident Response Plan and conduct annual testing.

5.3 Evidence shall be preserved in accordance with forensic standards.

5.4 Post-incident reviews shall be conducted within 14 days of incident closure.

6. Compliance / Framework Alignment

ISO/IEC 27001:2022 A.5.24-A.5.28; NIST CSF RS.RP, RS.CO, RC.RP; NDPA 2023 (breach notification within 72 hours).

7. Exceptions

As per Enterprise Policy Section 7.

8. Enforcement

Failure to report an incident may result in disciplinary action.

9. Monitoring and Metrics

Mean time to detect (MTTD); mean time to respond (MTTR); incident recurrence rate.

10. Review and Version Control

Annual review.

11. Related Documents

- Incident Response Procedure
- Business Continuity Plan

Policy 6: Mobile Device and Endpoint Security Policy

Owner	Approver	Version	Effective	Review
CISO	CISO	1.0	1 Oct 2026	1 Oct 2027

1. Purpose

To define minimum security requirements for organization-owned and authorized personal devices accessing ICDFA resources.

2. Scope

All endpoints (laptops, desktops, mobile devices) accessing ICDFA networks or data.

3. Definitions

- BYOD: Bring Your Own Device.
- MDM: Mobile Device Management.

4. Roles and Responsibilities

- IT Operations: Manage MDM enrollment and endpoint compliance.
- Users: Maintain device compliance.

5. Policy Statements

- 5.1 All endpoints shall have current anti-malware protection and OS patches.
- 5.2 BYOD devices shall be enrolled in MDM and meet minimum security baselines.
- 5.3 Full-disk encryption shall be enabled on all endpoints.
- 5.4 Lost or stolen devices shall be reported immediately.

6. Compliance / Framework Alignment

ISO/IEC 27001:2022 A.8.1, A.8.7; NIST CSF PR.PT.

7. Exceptions

As per Enterprise Policy Section 7.

8. Enforcement

Non-compliant devices may be blocked from network access.

9. Monitoring and Metrics

Endpoint compliance rate; patch compliance rate.

10. Review and Version Control

Annual review.

11. Related Documents

- BYOD Standard
- Endpoint Hardening Baseline

Policy 7: Cloud Security Policy

Owner	Approver	Version	Effective	Review
CISO	CISO	1.0	1 Oct 2026	1 Oct 2027

1. Purpose

To define requirements for approved cloud services, configuration, identity, logging, data protection, third-party risk, and shared-responsibility governance.

2. Scope

All cloud services used for ICDFA data or operations.

3. Definitions

- Shared Responsibility Model: Division of security responsibilities between cloud provider and customer.

4. Roles and Responsibilities

- CISO: Approve cloud services and oversee security.
- IT Operations: Configure and monitor cloud environments.

5. Policy Statements

- 5.1 All cloud services shall be approved by the CISO prior to use.
- 5.2 Cloud configurations shall comply with the ICDFA Cloud Security Baseline.
- 5.3 Logging shall be enabled and retained for at least 12 months.
- 5.4 Data stored in cloud services shall be classified and protected per the Data Classification Policy.

6. Compliance / Framework Alignment

ISO/IEC 27001:2022 A.5.23; NIST CSF ID.SC, PR.DS; NDPA 2023 (cross-border transfer restrictions).

7. Exceptions

As per Enterprise Policy Section 7.

8. Enforcement

Unauthorized cloud usage may result in service termination and disciplinary action.

9. Monitoring and Metrics

Number of approved vs. shadow cloud services; cloud configuration compliance rate.

10. Review and Version Control

Annual review.

11. Related Documents

- Cloud Security Baseline
- Third-Party Risk Management Procedure

Policy 8: Physical Security Policy

Owner	Approver	Version	Effective	Review
CISO	CISO	1.0	1 Oct 2026	1 Oct 2027

1. Purpose

To define controls for facilities, classrooms, laboratories, devices, media, visitor access, and physical asset protection.

2. Scope

All ICDFFA facilities, including offices, classrooms, laboratories, and data centers.

3. Definitions

- Restricted Area: Areas containing sensitive information assets.

4. Roles and Responsibilities

- Facilities Management: Implement physical controls.
- All Users: Comply with access restrictions and challenge unknown individuals.

5. Policy Statements

- 5.1 Access to restricted areas shall be limited to authorized personnel.
- 5.2 Visitors shall be escorted and logged.
- 5.3 Physical media shall be stored securely and disposed of securely.
- 5.4 Security cameras shall be installed in critical areas.

6. Compliance / Framework Alignment

ISO/IEC 27001:2022 A.7.1-A.7.6; NIST CSF PR.AC.

7. Exceptions

As per Enterprise Policy Section 7.

8. Enforcement

Unauthorized access may result in disciplinary action and legal referral.

9. Monitoring and Metrics

Visitor log completeness; access control audit findings.

10. Review and Version Control

Annual review.

11. Related Documents

- Visitor Management Procedure
- Data Disposal Procedure

Task 3: Framework and Control Mapping

Policy / Requirement	Business or Risk Objective	ISO/IEC 27001:2022 Alignment	NIST CSF 2.0 Function	Legal / Regulatory Note
Enterprise Policy 5.1: Maintain ISMS aligned with ISO 27001	Establish governance framework	Clause 4-10 (Management System)	Govern (GV)	NDPA 2023 requires accountability for data protection
Enterprise Policy 5.2: Risk-based approach	Prioritize security investments	Clause 6.1 (Risk Assessment)	Govern (GV.RM)	—
AUP 5.2: Prohibit unauthorized access attempts	Prevent unauthorized entry	A.5.15 (Access Control)	Protect (PR.AA)	Cybercrimes Act 2015 s.6 (unauthorized access)

Policy / Requirement	Business or Risk Objective	ISO/IEC 27001:2022 Alignment	NIST CSF 2.0 Function	Legal / Regulatory Note
AUP 5.3: No credential sharing	Ensure accountability	A.5.17 (Authentication Information)	Protect (PR.AA)	—
Access Control 5.1: Least privilege	Limit attack surface	A.5.15, A.8.3 (Information Access Restriction)	Protect (PR.AA)	—
Access Control 5.3: MFA for remote/privileged access	Strengthen authentication	A.8.5 (Secure Authentication)	Protect (PR.AA)	—
Access Control 5.5: Disable accounts within 24 hours	Prevent orphaned access	A.5.16 (Identity Management)	Protect (PR.AA)	—
Data Classification 5.2: Encrypt Confidential/Restricted data	Protect data confidentiality	A.8.24 (Cryptography)	Protect (PR.DS)	NDPA 2023 s.39 (security of processing)
Data Classification 5.4: Secure disposal	Prevent data remanence	A.7.10, A.8.10 (Information Deletion)	Protect (PR.DS)	NDPA 2023 (storage limitation)
Incident Response 5.1: Report within 1 hour	Minimize impact	A.5.24, A.5.25 (Incident Management)	Respond (RS.MA)	NDPA 2023 s.40 (72-hour breach notification)
Incident Response 5.3: Evidence preservation	Support investigation and legal action	A.5.28 (Collection of Evidence)	Respond (RS.AN)	Cybercrimes Act 2015 (evidence requirements)
Mobile/Endpoint 5.1: Anti-malware and patching	Prevent endpoint compromise	A.8.7 (Protection Against Malware), A.8.8 (Technical Vulnerabilities)	Protect (PR.PS)	—
Cloud Security 5.1: CISO approval for cloud services	Manage third-party risk	A.5.23 (Cloud Services Security)	Govern (GV.SC)	NDPA 2023 s.41 (cross-border transfer restrictions)
Cloud Security 5.3: Logging retention 12 months	Enable detection and forensics	A.8.15 (Logging)	Detect (DE.CM)	Cybercrimes Act 2015 s.38 (data retention)
Physical Security 5.1: Restricted area access control	Protect physical assets	A.7.2, A.7.3 (Physical Entry)	Protect (PR.AA)	—
Physical Security 5.2: Visitor logging	Maintain accountability	A.7.2 (Physical Entry Controls)	Protect (PR.AA)	—

Task 4: Implementation, Communication, and Exception Management

4.1 Communication Plan

Audience	Method	Frequency	Responsible
Staff	Email, intranet, team meetings	Upon publication; quarterly reminders	CISO + HR
Students	Student portal, orientation, LMS	Upon enrollment; annually	CISO + Academic Affairs
Instructors	Faculty meetings, email	Upon publication; annually	CISO + Academic Affairs
Administrators	Department meetings, email	Upon publication; quarterly	CISO
Third Parties	Contract addendum, email	Upon contracting; annually	Legal + CISO

4.2 Training and Awareness Plan

Role	Training Content	Frequency	Delivery Method
All Users	Security fundamentals, AUP, incident reporting	Annually + upon hire	Online module
Privileged Users	Privileged access responsibilities, incident response	Annually	Instructor-led
Managers	Policy enforcement, access approval	Annually	Workshop
IRT Members	Incident response procedures, forensics	Semi-annually	Simulation/exercise

4.3 Leadership Endorsement

- Governing Council issues formal statement of support at policy launch.
- CISO presents quarterly security metrics to senior management.
- Visible sponsorship at all-staff meetings and orientation events.

4.4 Implementation Sequencing

Priority	Policy/Activity	Timeline
1	Enterprise Information Security Policy	Week 1-2
2	Access Control Policy + AUP	Week 3-4
3	Incident Response Policy	Week 5-6
4	Data Classification Policy	Week 7-8
5	Cloud Security Policy	Week 9-10

Priority	Policy/Activity	Timeline
6	Mobile/Endpoint + Physical Security Policies	Week 11-12

4.5 Supporting Tools

Templates: Policy template, Exception Request Form, Access Review Checklist.

Technical Controls: MDM solution, SIEM, MFA infrastructure, DLP.

Systems: Policy management platform, LMS for training.

4.6 Exception Process

1. Request: Submitted via Exception Request Form with business justification.
2. Risk Assessment: CISO evaluates risk and required compensating controls.
3. Approval: CISO approves/rejects; high-risk exceptions require Risk Committee approval.
4. Recording: All exceptions logged in Exception Register.
5. Expiry: Maximum 12 months; renewal requires re-assessment.
6. Review: Exceptions reviewed quarterly for ongoing validity.

4.7 Continuous Improvement

- Annual policy review cycle.
- Post-incident reviews inform policy updates.
- User feedback via annual security survey.
- Audit findings drive corrective actions.

Task 5: Policy Effectiveness and Management Metrics

#	Metric	Owner	Data Source	Frequency	Target	Reporting To	Action if Missed
1	Policy acknowledgement rate	CISO	LMS/Policy platform	Quarterly	≥95%	Senior Management	Remedial awareness campaign
2	Security awareness training completion	HR	LMS	Quarterly	≥90%	CISO	Manager escalation; access restriction
3	Access review completion rate	IT Operations	Access review system	Quarterly	100%	CISO	Escalate to system owners
4	Number/age/recurrence of policy exceptions	CISO	Exception Register	Quarterly	<10 open; none >12 months	Risk Committee	Remediation plan required

#	Metric	Owner	Data Source	Frequency	Target	Reporting To	Action if Missed
5	Incidents due to policy non-compliance	IRT	Incident records	Monthly	Trend down	CISO	Root cause analysis; policy update
6	Critical audit findings remediation status	Compliance	Audit reports	Quarterly	100% closed within 30 days	Governing Council	Escalation to management
7	Policies reviewed within cycle	CISO	Policy register	Annually	100%	Governing Council	Expedited review
8	Endpoint compliance rate	IT Operations	MDM console	Monthly	≥98%	CISO	Remediation or network restriction
9	Cloud configuration compliance	IT Operations	CSPM tool	Monthly	≥95%	CISO	Auto-remediation; manual review
10	Incident MTTD and MTTR	IRT	SIEM/ticketing	Monthly	MTTD <1h; MTTR <4h	CISO	Process improvement review

References

ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements.

ISO/IEC 27002:2022 – Information security controls.

NIST Cybersecurity Framework 2.0 (2024).

Nigeria Data Protection Act 2023.

Cybercrimes (Prohibition, Prevention, etc.) Act 2015 (Nigeria).